

Naan Mudhalvan Project

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

TEAMMATES DETAILS TEAM NO: 1

TEAM ID: 69a6781b724da7484d4b8fdc

TEAM LEADER: Balaganesh.K

**COLLEGE NAME: Rathinam College of Liberal Arts & Science
@Tips Global**

COLLEGE CODE: CD

LIST OF TEAMMATES:

S . No	NAME	CONTACT EMAIL
1.	BALAGANESH K	kanagarajbalaganesh@gmail.com
2.	JANANI L	jananilingan25@gmail.com
3.	KOUSALYA R	rkousalya855@gmail.com
4.	ARUNKUMAR ARUNACHALAM	arunkumar.9847539538@gmail.com
5.	NAVEEN G	ganefhand947@gmail.com

Abstract:

Traditional Virtual Private Network (VPN) architectures were designed for earlier network environments where users and applications were primarily located inside corporate data centers. However, with the rapid adoption of cloud computing, remote work, and mobile devices, legacy VPN systems have become inefficient and vulnerable to modern cyber threats. VPNs typically grant broad network access once a user is authenticated, which increases the attack surface and enables lateral movement if an attacker compromises a single endpoint.

This project focuses on replacing and modernizing legacy VPN infrastructures with a cloud-native Zero Trust architecture using **Zscaler** security solutions. The

Zero Trust model operates on the principle of “never trust, always verify,” ensuring that users, devices, and applications are continuously authenticated and authorized before gaining access to resources. Instead of providing full network access like traditional VPNs, the **Zscaler Zero Trust Exchange** platform connects users directly to specific applications through secure, identity-based policies.

By implementing Zscaler’s cloud-delivered security platform, organizations can significantly reduce their attack surface, eliminate unnecessary network exposure, and prevent lateral movement within the network. The architecture also enhances performance by connecting users to the nearest cloud security gateway, eliminating the need for backhauling traffic through centralized VPN gateways.

Overall, the modernization of legacy VPN systems with Zscaler’s Zero Trust approach provides improved security, better scalability, simplified network management, and an optimized user experience in today’s distributed and cloud-centric IT environments.

Use Case Scenarios:

1. Secure Remote Workforce Access

Scenario:

A company allows employees to work remotely. Earlier, employees used a traditional VPN to connect to the corporate network.

Problem with Legacy VPN:

- Full network access once connected
- Higher risk of cyber attacks
- Difficult to manage remote devices

Zscaler Zero Trust Solution:

- Employees access only specific applications
- Identity-based authentication
- No direct network exposure

Output:

- Reduced attack surface
- Secure remote access for employees
- Improved user experience and faster connectivity

2. Third-Party Vendor Access Control

Scenario:

A manufacturing company allows external vendors to access internal systems for maintenance and support.

Problem with Legacy VPN:

- Vendors receive broad network access
- Risk of unauthorized data access
- Difficult to monitor vendor activities

Zscaler Zero Trust Solution:

- Vendors get **application-specific access**
- Policy-based authentication
- Continuous monitoring

Output:

- Limited access only to required resources
- Improved security for sensitive data
- Reduced insider threat risk

3. Secure Cloud Application Access

Scenario:

An organization uses cloud applications like CRM and ERP systems hosted in the cloud.

Problem with Legacy VPN:

- Traffic backhauled to the data center
- Increased latency
- Complex network configuration

Zscaler Zero Trust Solution:

- Direct secure connection to cloud apps

- Identity-based access policies
- Cloud-native security gateway

Output:

- Faster access to cloud services
- Improved application performance
- Reduced infrastructure complexity

4. Protection Against Lateral Movement

Scenario:

A cyber attacker gains access to a user device through phishing or malware.

Problem with Legacy VPN:

- Once inside VPN, attacker can move laterally across the network
- Multiple systems become vulnerable

Zscaler Zero Trust Solution:

- Micro-segmented access
- Continuous verification of users and devices
- No internal network visibility

Output:

- Prevents lateral movement of attackers
- Limits damage to a single application
- Stronger overall network security

5. Secure Branch Office Connectivity

Scenario:

A company operates multiple branch offices connected through traditional VPN tunnels.

Problem with Legacy VPN:

- High maintenance cost
- Complex network management
- Limited scalability

Zscaler Zero Trust Solution:

- Branch offices connect directly to Zscaler cloud
- Secure internet and application access
- Centralized security policies

Output:

- Simplified network management
- Reduced infrastructure cost
- Scalable and secure branch connectivity

Stage 1

TITLE:

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

OVERVIEW:

In today's digital environment, organizations rely heavily on cloud services, remote work, and mobile devices. Traditional network security models were designed when most employees worked inside an office network and accessed applications from a centralized data center. To allow remote access, companies used **Virtual Private Networks (VPNs)** to connect users securely to internal networks. Although VPNs were effective in earlier network environments, they now present several security and performance challenges in modern enterprise infrastructures.

Legacy VPN architectures typically grant users broad access to the internal network once they successfully authenticate. This model assumes that users inside the network are trustworthy. However, modern cyber threats such as phishing attacks, ransomware, and credential theft have proven that this approach is no longer secure. If an attacker gains access to a VPN account or compromises a user's device, they can move freely within the corporate network and access sensitive systems. This type of unauthorized movement within the network is known as **lateral movement**, and it significantly increases the risk of data breaches and system compromise.

To address these challenges, many organizations are moving toward a **Zero Trust security model**. Zero Trust is based on the principle of "**Never Trust, Always Verify.**" Instead of assuming that users inside the network are safe, Zero Trust requires continuous verification of users, devices, and access requests before granting access to applications or resources. This approach limits access only to what is necessary and prevents unauthorized users from exploring the internal network.

A leading platform that enables Zero Trust architecture is provided by Zscaler. Zscaler offers a **cloud-native security platform** that replaces traditional VPN-based access with a secure, identity-driven connection to applications. Rather than connecting users directly to the corporate network, Zscaler connects users securely to the specific applications they need. This approach removes the need to expose internal networks to external connections.

In a traditional VPN architecture, all remote users connect to a centralized VPN gateway located in the organization's data center. This can create network congestion, increase latency, and reduce application performance. In addition, maintaining VPN infrastructure requires significant

hardware, maintenance, and administrative effort. As organizations expand globally and adopt cloud-based applications, these limitations become even more significant.

A cloud-native Zero Trust solution eliminates these challenges by moving security enforcement to the cloud. With Zscaler's architecture, users connect to the nearest security node within the Zscaler cloud. The platform then verifies the user's identity, device posture, and access policy before allowing the connection to the application. Since the connection is made directly to the application rather than the internal network, the internal infrastructure remains hidden from external users and attackers.

One of the key advantages of implementing Zscaler Zero Trust is the **reduction of the attack surface**. In traditional networks, many internal applications are exposed to users once they connect through the VPN. Attackers who gain VPN access can scan the network and identify vulnerable systems. With Zero Trust architecture, applications are hidden behind the security platform, making them invisible to unauthorized users. This significantly reduces the opportunities for attackers to exploit vulnerabilities.

Another important benefit is the **prevention of lateral movement**. In a Zero Trust environment, each application request is evaluated independently. Users are granted access only to specific applications based on their identity, role, and security policies. Even if a user account is compromised, the attacker cannot move freely within the network because other systems remain inaccessible. This containment strategy limits the potential damage caused by security breaches.

In addition to improved security, Zscaler Zero Trust solutions also enhance **network performance and scalability**. Because the platform operates in the cloud, users can connect directly to applications without routing traffic through centralized data centers. This reduces latency and improves the user experience, especially for employees accessing cloud-based services from different geographic locations.

Organizations also benefit from **simplified network management**. Traditional VPN infrastructures require constant updates, hardware maintenance, and capacity planning to support increasing numbers of users. Cloud-native security platforms like Zscaler eliminate much of this complexity by providing a scalable, cloud-based service. IT teams can manage security policies centrally and monitor access activity through a single platform.

Furthermore, Zero Trust architectures support modern workplace environments where employees work from various locations and devices. Whether users are working from home, traveling, or accessing applications from branch offices, the same security policies apply. This ensures consistent protection across all users and devices regardless of their location.

List of Vulnerability Table:

S . No	Category Name	Vulnerability Name	CWE/CVE-No
1	Broken Access Control	Absolute Path Traversal	CWE-36
2	Security Misconfiguration	Active Debug Code	CWE-489
3	Software Supply Chain Failures	Unimplemented or Unsupported Feature in UI	CWE-447
4	Injection	Process Control	CWE-114
5	Cryptographic Failures	Weak encoding for password	CWE-261
6	Insecure Design	Improper privilege management	CWE-269
7	Authentication Failures	Session fixation	CWE-384
8	Software or Data Integrity Failures	Untrusted search path	CWE-426
9	Security Logging and Alerting Failures	Insufficient Logging	CWE-778
10	Mishandling of Exceptional Conditions	Improper Error Handling	CWE-703

1. Vulnerability Report

Vulnerability Name: Absolute Path Traversal

CWE: CWE-36

The screenshot shows the MITRE Common Weakness Enumeration (CWE) website page for CWE-36: Absolute Path Traversal. The page includes a navigation bar with links to Home, About, Learn, Access Content, Community, and Search. The main content area is titled "CWE-36: Absolute Path Traversal" and provides detailed information about this vulnerability. It includes a description, an extended description, and common consequences. The page also features a "View customized information" section with buttons for Conceptual, Operational, Mapping Friendly, Complete, and Custom views. The "Impact" section is expanded, showing details for "Execute Unauthorized Code or Commands", "Modify Files or Directories", and "Read Files or".

CWE-36: Absolute Path Traversal

Weakness ID: 36
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information:

Description
The product uses external input to construct a pathname that should be within a restricted directory, but it does not properly neutralize absolute path sequences such as "/abs/path" that can resolve to a location that is outside of that directory.

Extended Description
This allows attackers to traverse the file system to access files or directories that are outside of the restricted directory.

Common Consequences

Impact	Details
Execute Unauthorized Code or Commands	Scope: Integrity, Confidentiality, Availability The attacker may be able to create or overwrite critical files that are used to execute code, such as programs or libraries.
Modify Files or Directories	Scope: Integrity The attacker may be able to overwrite or create critical files, such as programs, libraries, or important data. If the targeted file is used for a security mechanism, then the attacker may be able to bypass that mechanism. For example, appending a new account at the end of a password file may allow an attacker to bypass authentication.
Read Files or	Scope: Confidentiality The attacker may be able to read the contents of unexpected files and expose sensitive data. If the targeted file is used for a security mechanism, then

OWASP/SANS Category: Path Traversal / Improper Input Validation

Description:

Absolute Path Traversal occurs when a web application uses user input to access files or directories on the server without properly validating the input. In this vulnerability, attackers can provide an **absolute file path** (such as system directories) to access files outside the intended restricted folder. Because the application fails to properly sanitize or validate the file path, attackers may read or manipulate sensitive files stored on the server. This vulnerability usually occurs due to improper input validation, insecure file handling, or lack of directory restrictions.

Business Impact:

If attackers exploit this vulnerability, they may gain access to sensitive files such as configuration files, system data, or user information. In some cases, attackers may modify or overwrite important system files, which can lead to system compromise or service disruption. This can result in **data breaches, loss of confidentiality, operational downtime, financial losses, and damage to the organization's reputation.**

2. Vulnerability Report

Vulnerability Name: Active Debug Code

CWE: CWE-489

The screenshot shows the MITRE CWE website page for CWE-489: Active Debug Code. The page includes the MITRE logo, navigation links, and a search bar. The main content area displays the vulnerability name, ID (489), and mapping (ALLOWED). It also features a description of the vulnerability and a code snippet illustrating the issue. The code snippet shows a debug interface that prints a welcome message and logs the user, which is highlighted with a red circle. The description states: "The product is released with debugging code still enabled or active."

CWE-489: Active Debug Code

Weakness ID: 489
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information:

Description

The product is released with debugging code still enabled or active.

```
<Product code/>
~~~~~
~~~~~
~~~~~
#Debug - remove debug code before release
if username is "SecretDebugUser":
    print("Welcome to the debug interface! No need for a password!")
    login(SecretDebugUser)
~~~~~
~~~~~
```

Alternate Terms

Leftover debug code | This term originates from Seven Pernicious Kingdoms

OWASP/SANS Category: Security Misconfiguration / Information Exposure

Description:

Active Debug Code occurs when an application or software product is released with debugging code still enabled. Debugging code is typically used by developers during testing to identify errors or monitor system behavior. If this code remains active in the production environment, it may expose sensitive system information, hidden functions, or administrative access points. Attackers can exploit these debug features to gain unauthorized access or learn details about the internal system structure.

Business Impact:

If attackers exploit this vulnerability, they may obtain sensitive information such as system configurations, internal code logic, or authentication mechanisms. In some cases, attackers may bypass security controls or gain administrative access. This can lead to **data breaches, system compromise, operational disruption, and damage to the organization's reputation.**

3. Vulnerability Report

Vulnerability Name: Unimplemented or

Unsupported Feature in UI

CWE: CWE-447

The screenshot shows the MITRE CWE website page for CWE-447: Unimplemented or Unsupported Feature in UI. The page includes a navigation bar with links like Home, About, Learn, Access Content, Community, and Search. The main content area displays the vulnerability details, including a description, common consequences, potential mitigations, and relationships. The page is titled "CWE-447: Unimplemented or Unsupported Feature in UI" and includes a "View customized information" section with tabs for Conceptual, Operational, Mapping Friendly, Complete, and Custom. The description states: "A UI function for a security feature appears to be supported and gives feedback to the user that suggests that it is supported, but the underlying functionality is not implemented." The common consequences section shows "Impact" as "Varies by Context; Unexpected State" and "Details" as "Scope: Other". The potential mitigations section shows "Phase(s)" as "Testing" and "Mitigation" as "Perform functionality testing before deploying the application." The relationships section shows "Relevant to the view 'Research Concepts' (View-1000)" with a table of relationships.

CWE-447: Unimplemented or Unsupported Feature in UI

Weakness ID: 447
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information:

Description
A UI function for a security feature appears to be supported and gives feedback to the user that suggests that it is supported, but the underlying functionality is not implemented.

Common Consequences

Impact	Details
Varies by Context; Unexpected State	Scope: Other

Potential Mitigations

Phase(s)	Mitigation
Testing	Perform functionality testing before deploying the application.

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
--------	------	----	------

OWASP/SANS Category: Security Misconfiguration / Improper Design

Description:

This vulnerability occurs when a user interface (UI) shows or suggests that a security feature is available, but the actual functionality behind it is not implemented or supported. The system may display buttons, options, or messages that indicate a security control exists, even though the feature does not work in the backend. This can mislead users into believing that certain protections are active when they are not.

Business Impact:

If this vulnerability is exploited, users may rely on security features that do not actually function, which can leave systems and sensitive data unprotected. Attackers may take advantage of the

missing security control to bypass protection mechanisms. This can result in **security gaps, unauthorized access, data exposure, and loss of user trust in the application.**

4. Vulnerability Report

Vulnerability Name: Process Control

CWE: CWE-114

The screenshot shows the CWE-114: Process Control page on the Common Weakness Enumeration website. The page header includes the CWE logo, the title "Common Weakness Enumeration", and a subtitle "A community-developed list of SW & HW weaknesses that can become vulnerabilities". The page is titled "CWE-114: Process Control (4.19.1)". The page content includes a "Weakness ID: 114" section, a "Vulnerability Mapping: DISCOURAGED" section, and an "Abstraction: Class" section. Below these are tabs for "View customized information: Conceptual, Operational, Mapping Friendly, Complete, Custom". The "Description" section states: "Executing commands or loading libraries from an untrusted source or in an untrusted environment can cause an application to execute malicious commands (and payloads) on behalf of an attacker." The "Extended Description" section states: "Process control vulnerabilities take two forms: An attacker can change the command that the program executes: the attacker explicitly controls what the command is. An attacker can change the environment in which the command executes: the attacker implicitly controls what the command means." The "Common Consequences" section includes a table with "Impact" and "Details" columns. The "Impact" column lists "Execute Unauthorized Code or Commands" and the "Details" column lists "Scope: Confidentiality, Integrity, Availability". The "Potential Mitigations" section is partially visible at the bottom.

OWASP/SANS Category: Injection / Improper Input Validation

Description:

Process Control vulnerability occurs when an application executes commands or loads libraries from untrusted sources without proper validation. If the application allows external input to influence system commands or program execution, attackers may manipulate the input to execute malicious commands. This can allow attackers to control how a program runs or change the environment in which the command is executed.

Business Impact:

If attackers exploit this vulnerability, they may execute unauthorized commands on the system.

This can allow them to install malware, modify system files, or gain higher privileges within the system. As a result, it may lead to **system compromise, data theft, service disruption, and serious security risks to the organization.**

5. Vulnerability Report

Vulnerability Name: Weak Cryptographic Algorithm

CWE: 261

The screenshot shows a web browser window displaying the MITRE Common Weakness Enumeration (CWE) page for CWE-261: Weak Encoding for Password. The page includes a navigation bar with links to Home, About, Learn, Access Content, Community, and Search. The main content area provides detailed information about the weakness, including its description, extended description, common consequences, potential mitigations, and relationships. The page also features a search bar and a 'New to CWE?' link.

CWE-261: Weak Encoding for Password

Weakness ID: 261
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information:

Description
Obscuring a password with a trivial encoding does not protect the password.

Extended Description
Password management issues occur when a password is stored in plaintext in an application's properties or configuration file. A programmer can attempt to remedy the password management problem by obscuring the password with an encoding function, such as base 64 encoding, but this effort does not adequately protect the password.

Common Consequences

Impact	Details
Gain Privileges or Assume Identity	Scope: Access Control

Potential Mitigations

Phase(s)	Mitigation
	Passwords should be encrypted with keys that are at least 128 bits in length for adequate security.

Relationships

OWASP/SANS Category: Cryptographic Failures

Description:

Using weak encoding techniques such as simple encoding (for example Base64) instead of proper encryption for storing passwords does not provide real security. Attackers can easily decode the **encoded data and access sensitive information.**

Business Impact:

If attackers decode the encoded passwords, they can gain unauthorized access to user accounts and sensitive systems, which may lead to data breaches and loss of confidentiality. 🗝️

6. Vulnerability Report

Vulnerability Name: Improper privilege management

CWE: CWE-269

The screenshot shows the CWE-269: Improper Privilege Management page. The page header includes the CWE logo and navigation links. The main content area displays the weakness ID (269), its mapping to DISCOURAGED, and its abstraction class. Below this, there are tabs for 'View customized information' (Conceptual, Operational, Mapping Friendly, Complete, Custom). The 'Description' section contains a diagram illustrating the vulnerability: a 'Guest User' interacts with a 'Product' (represented by a blue box with a smiley face). The user sends a 'Say Hello World' message, which the product processes successfully, resulting in a 'Hello World' response. However, the user also sends a 'Delete DATABASE' message, which the product processes incorrectly (indicated by a red 'X' and a red arrow pointing to a database icon), leading to an unintended sphere of control for that actor. The 'Common Consequences' section lists 'Gain Privileges or Assume Identity' as the impact, with a scope of 'Access Control'. The 'Potential Mitigations' section is partially visible at the bottom.

WASP/SANS Category: Broken Access Control / Improper Authorization

Description:

Improper Privilege Management occurs when an application fails to correctly assign, modify, or enforce user privileges. This vulnerability allows users to perform actions beyond their authorized permissions because the system does not properly manage or verify access rights. It often occurs due to poor access control mechanisms, missing permission checks, or incorrect privilege assignments within the system.

Business Impact:

If attackers exploit this vulnerability, they may gain higher privileges or access restricted system functions. This can allow them to view sensitive information, modify important data, or perform administrative actions without authorization. As a result, it may lead to **data breaches, system misuse, loss of data integrity, and serious security risks for the organization.**

7. Vulnerability Report

Vulnerability Name: Session fixation

CWE: CWE-384

The screenshot shows the MITRE Common Weakness Enumeration (CWE) website page for CWE-384: Session Fixation. The page is titled "CWE-384: Session Fixation (4.19.1)" and includes a navigation bar with links for Home, About, Learn, Access Content, Community, and Search. The main content area is divided into several sections:

- Weakness ID: 384 (Structure: Composite)**
- Vulnerability Mapping: ALLOWED**
- View customized information:** Conceptual, Operational, Mapping Friendly, Complete, Custom
- Description:** Authenticating a user, or otherwise establishing a new user session, without invalidating any existing session identifier gives an attacker the opportunity to steal authenticated sessions.
- Extended Description:** Such a scenario is commonly observed when:
 - A web application authenticates a user without first invalidating the existing session, thereby continuing to use the session already associated with the user.
 - An attacker is able to force a known session identifier on a user so that, once the user authenticates, the attacker has access to the authenticated session.
 - The application or container uses predictable session identifiers.In the generic exploit of session fixation vulnerabilities, an attacker creates a new session on a web application and records the associated session identifier. The attacker then causes the victim to associate, and possibly authenticate, against the server using that session identifier, giving the attacker access to the user's account through the active session.
- Common Consequences:**
 - Impact:** Gain Privileges or Assume Identity
 - Details:** Scope: Access Control
- Potential Mitigations:** A table with columns for Phase(s) and Mitigation.

OWASP/SANS Category: Broken Authentication and Session Management

Description:

Session Fixation occurs when a web application does not assign a new session ID after a user logs in. An attacker can set or predict a known session ID and trick the user into using it. Once the user logs in with that session ID, the attacker can use the same session to gain unauthorized access.

Business Impact:

Attackers may hijack a valid user session and gain unauthorized access to the user's account, leading to data theft, privacy violations, and potential compromise of sensitive information.

8. Vulnerability Report

Vulnerability Name: Untrusted search path

CWE: CWE-426

The screenshot shows the CWE-426: Untrusted Search Path page on the Common Weakness Enumeration (CWE) website. The page is titled "CWE-426: Untrusted Search Path" and includes a "Weakness ID: 426" and "Vulnerability Mapping: ALLOWED (with careful review of mapping notes)". The "Abstraction" is listed as "Base". Below this, there are tabs for "View customized information": "Conceptual", "Operational", "Mapping Friendly", "Complete", and "Custom". The "Description" section states: "The product searches for critical resources using an externally-supplied search path that can point to resources that are not under the product's direct control." The "Extended Description" section explains: "This might allow attackers to execute their own programs, access unauthorized data files, or modify configuration in unexpected ways. If the product uses a search path to locate critical resources such as programs, then an attacker could modify that search path to point to a malicious program, which the targeted product would then execute. The problem extends to any type of critical resource that the product trusts. Some of the most common variants of untrusted search path are:" followed by a bulleted list: "In various UNIX and Linux-based systems, the PATH environment variable may be consulted to locate executable programs, and LD_PRELOAD may be used to locate a separate library." and "In various Microsoft-based systems, the PATH environment variable is consulted to locate a DLL, if the DLL is not found in other paths that appear earlier in the search order." Below the description, there are sections for "Alternate Terms" (listing "Untrusted Path") and "Common Consequences" (listing "Impact" and "Details"). The "Impact" section is currently selected, showing the text "Gain Privileges or".

OWASP/SANS Category: Security Misconfiguration

Description:

Untrusted Search Path vulnerability occurs when an application searches for executable files or libraries in directories that can be modified by attackers. If the application loads a malicious file from an untrusted location, attackers may execute unauthorized code on the system.

Business Impact:

Attackers may run malicious programs or gain unauthorized access to the system, which can lead to system compromise, data theft, or disruption of application services.

9. Vulnerability Report

Vulnerability Name: Insufficient Logging and Monitoring

CWE: CWE-778

The screenshot shows the MITRE Common Weakness Enumeration (CWE) website page for CWE-778: Insufficient Logging. The page includes a navigation bar with links like Home, About, Learn, Access Content, Community, and Search. The main content area is titled "CWE-778: Insufficient Logging" and provides detailed information about this weakness, including its description, extended description, common consequences, and potential mitigations.

CWE-778: Insufficient Logging

Weakness ID: 778
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information:

Description
When a security-critical event occurs, the product either does not record the event or omits important details about the event when logging it.

Extended Description
When security-critical events are not logged properly, such as a failed login attempt, this can make malicious behavior more difficult to detect and may hinder forensic analysis after an attack succeeds.
As organizations adopt cloud storage resources, these technologies often require configuration changes to enable detailed logging information, since detailed logging can incur additional costs. This could lead to telemetry gaps in critical audit logs. For example, in Azure, the default value for logging is disabled.

Common Consequences

Impact	Details
Hide Activities	Scope: Non-Repudiation If security critical information is not recorded, there will be no trail for forensic analysis and discovering the cause of problems or the source of attacks may become more difficult or impossible.

Potential Mitigations

Phase(s)	Mitigation
Architecture and Design	Use a centralized logging mechanism that supports multiple levels of detail.
Implementation	Ensure that all security-related successes and failures can be logged. When storing data in the cloud (e.g., AWS S3 buckets, Azure blobs, Google Cloud Storage, etc.), use the provider's controls to enable and capture detailed logging information.

OWASP/SANS Category: Security Logging and Monitoring Failures

Description:

When systems do not properly log or monitor security events, suspicious activities may go unnoticed.

Business Impact:

Attackers can remain undetected and continue exploiting the system.

OWASP/SANS Category: Security Logging and Monitoring Failures

Description:

When systems do not properly log or monitor security events, suspicious activities may go unnoticed.

Business Impact:

Attackers can remain undetected and continue exploiting the system.

10. Vulnerability Report

Vulnerability Name: Improper Error Handling

CWE: CWE-703

cwe.mitre.org/data/definitions/703.html

CWE Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 Top HW CWE New to CWE? Start here!

Home > CWE List > CWE-703: Improper Check or Handling of Exceptional Conditions (4.19.1) ID Lookup: Go

Home About Learn Access Content Community Search

CWE-703: Improper Check or Handling of Exceptional Conditions

Weakness ID: 703
Vulnerability Mapping: **DISCOURAGED**
Abstraction: Pillar

View customized information:

▼ Description

The product does not properly anticipate or handle exceptional conditions that rarely occur during normal operation of the product.



▼ Common Consequences

Impact Details

Read Application Data; DoS; Crash, Exit, or Restart; Unexpected State

Scope: Confidentiality, Availability, Integrity

▼ Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
MemberOf	✓	1000	Research Concepts
ParentOf	✓	703	Improper Handling of Substantially Invalid Structure

OWASP/SANS Category: Security Misconfiguration / Error Handling Issues

Description:

Improper handling of exceptions may expose system information such as server paths or database queries.

Business Impact:

Attackers may use this information to plan further attacks.

Stage 2

OVERVIEW OF TENABLE NESSUS

Tenable Nessus is one of the most widely used vulnerability assessment tools designed to identify security weaknesses in computer systems, networks, and applications. It is developed by Tenable, Inc. and is used by security professionals to detect vulnerabilities, misconfigurations, outdated software, and potential security risks before attackers can exploit them.

Nessus works by scanning systems and comparing detected configurations against a large vulnerability database. It checks for known vulnerabilities, missing security patches, weak passwords, open ports, and insecure configurations. The tool generates detailed reports that describe each vulnerability, its severity level, potential impact, and recommended remediation steps.

One of the main advantages of Nessus is its large plugin library that continuously updates with new vulnerability checks. It supports scanning for operating systems, web applications, databases, and network devices. Nessus also categorizes vulnerabilities based on

risk levels such as **Info, Critical, High, Medium, and Low**, helping administrators prioritize security fixes.

Overall, Tenable Nessus plays a crucial role in proactive cybersecurity by helping organizations detect vulnerabilities early, strengthen their security posture, and protect their infrastructure from cyber threats. It is widely used in security auditing, compliance checking, penetration testing, and vulnerability management programs.

Target website: demo.testfire.net/

Target IP Address: 65.61.137.117

LIST OF VULNERABILITIES :

S.NO	VULNERABILITIES NAME	SEVERITY	PLUGINS ID
1	Port scanners	info	11219
2	Service detection	info	22964
3	General	info	54615
4	Setting	info	19506
5	General	Info	209654

1.VULNERABILITY NAME: Port Scanners

SEVERITY: Info

PLUGIN ID: 11219

PORT: N/A

DESCRIPTION:

A Port Scanner is a tool or process used to identify open ports and services running on a target system or network. During a security

scan, the scanner attempts to connect to multiple ports on the target host to determine which ports are open, closed, or filtered.

Open ports may indicate active services that could potentially be exploited if they are misconfigured or running outdated software. Attackers commonly perform port scanning as the first step of reconnaissance to gather information about the target system.

Although port scanning itself does not exploit a vulnerability, it reveals information about available services and network configurations. This information may help attackers plan further attacks against exposed services.

SOLUTION:

- **Disable Unnecessary Services:**

Close or disable any network services and ports that are not required for system operation. This reduces the attack surface of the system.

- **Use Firewalls and Access Control Lists:**

Configure firewalls to restrict access to only trusted IP addresses and block unauthorized port scanning attempts.

- **Implement Intrusion Detection/Prevention Systems (IDS/IPS):**

Deploy monitoring systems to detect and alert administrators when suspicious scanning activity is detected.

2.VULNERABILITY NAME: Service Detection

SEVERITY: Info

PLUGIN ID: 22964

PORT: N/A

DESCRIPTION:

Service Detection is the process used by security scanners to identify the services running on open ports of a target system. The scanner attempts to determine the service type, application name, and sometimes the version of the software running on those ports.

This information is useful for system administrators to understand which services are exposed on the network. However, it may also provide attackers with valuable information about the technologies and software versions used by the system.

SOLUTION:

- **Limit Information Disclosure:**

Configure services to minimize the amount of information revealed in banners or responses, such as application names and version numbers.

- **Disable Unnecessary Services:**

Turn off services that are not required for normal system operation to reduce the attack surface.

- **Use Firewalls and Network Segmentation:**

Restrict access to services using firewall rules and network segmentation to ensure that only authorized users or systems can access them.

- **Keep Services Updated:**

Regularly update and patch all services running on the system to protect against known vulnerabilities.

- **Implement Monitoring Systems:**

Deploy intrusion detection or prevention systems (IDS/IPS) to monitor and alert administrators about unusual network scanning activities.

3.VULNERABILITY NAME: General Information

SEVERITY: Info

PLUGIN ID: 54615

PORT: N/A

DESCRIPTION:

This informational finding indicates that the security scanner has gathered general information about the target system during the scanning process. The information collected may include details such as system configuration, available services, network responses, or other environmental data.

General information findings do not represent a direct security vulnerability. Instead, they provide useful details about the target environment that may assist security administrators in understanding the system configuration and identifying potential areas that require further security review.

Attackers often collect similar information during the reconnaissance phase of an attack to better understand the target system and plan further actions.

SOLUTION:

- **Review System Configuration:**

Regularly review system and network configurations to ensure that only necessary information is exposed to external users.

- **Limit Information Disclosure:**

Configure systems and applications to reduce unnecessary information exposure in banners, headers, or error messages.

- **Implement Network Security Controls:**

Use firewalls and access control mechanisms to restrict unauthorized access to system information.

- **Maintain Security Updates:**

Ensure that all systems, services, and applications are regularly updated and patched.

- **Perform Regular Security Assessments:**

Conduct periodic vulnerability assessments and security audits to identify and address potential risks.

4.VULNERABILITY NAME: Settings Information

SEVERITY: Info

PLUGIN ID: 19506

PORT: N/A

DESCRIPTION:

This informational finding indicates that the security scanner has identified configuration or settings information related to the target

system during the scanning process. The scanner records details about the system environment, scan configuration, and other relevant settings used during the vulnerability assessment.

These settings may include information about enabled services, system configurations, or security-related parameters that were detected during the scan. While this information does not represent a direct security vulnerability, it provides useful insights into the system's configuration and operational environment.

Attackers often attempt to gather configuration and system information during the reconnaissance phase in order to better understand the target system and identify potential weaknesses that may be exploited in future attacks.

SOLUTION:

- **Review System Configuration:**

Regularly review system and application settings to ensure that they follow security best practices.

- **Restrict Access to Configuration Data:**

Limit access to configuration files and system settings to authorized administrators only.

- **Minimize Information Exposure:**

Avoid exposing sensitive configuration details through publicly accessible services or error messages.

- **Apply Security Hardening:**

Implement system hardening techniques to reduce unnecessary services and configuration exposures.

- **Perform Regular Security Monitoring:**

Continuously monitor systems for unauthorized configuration changes and potential security risks.

5.VULNERABILITY NAME: General Information

SEVERITY: Info

PLUGIN ID: 209654

PORT: N/A

DESCRIPTION:

This informational finding indicates that the security scanner has collected general information about the target host during the vulnerability assessment process. The information gathered may include system responses, detected services, network configuration details, or other environmental information related to the scanned system.

Such findings are typically generated during the reconnaissance phase of the scanning process to help security teams better understand the system environment and identify areas that may require further investigation.

Although this finding does not represent a direct vulnerability, it highlights that certain information about the system is accessible and may be used for analysis during a security assessment.

Attackers may also attempt to gather similar information during the early stages of an attack to understand the system structure and identify potential entry points.

SOLUTION:

- **Review Information Exposure:**

Ensure that the system does not expose unnecessary information through service banners, error messages, or response headers.

- **Implement Security Controls:**

Use firewalls and network access control mechanisms to restrict unauthorized access to system information.

- **Apply System Hardening:**

Disable unnecessary services and remove unused components to minimize the system's attack surface.

- **Monitor Network Activity:**

- Use logging and monitoring tools to detect unusual scanning or reconnaissance activity.

- **Perform Regular Security Assessments:**

- Conduct periodic vulnerability assessments and penetration testing to identify and address potential security risks.

Stage 2: Analysis of Identified Vulnerabilities in the Nessus Scan

Stage 2 focuses on analyzing the vulnerabilities identified during the **Tenable Nessus vulnerability scan** of the target website. The Nessus report provides detailed information about the detected issues, including the vulnerability name, severity level, plugin ID, description, and recommended solutions. By reviewing these findings, security professionals can better understand the security posture of the target system and identify potential risks.

During the scan of the target website, several **informational vulnerabilities** were detected, including **Port Scanners, Service Detection, General Information, and Settings Information**. These findings mainly relate to system information disclosure and reconnaissance-related activities.

The **Port Scanners (Plugin ID: 11219)** vulnerability indicates that the scanner was able to identify open ports and active services on the target system. Open ports can reveal running services that might be misconfigured or outdated. Attackers often perform port scanning during the initial reconnaissance stage to gather information about the system.

The **Service Detection (Plugin ID: 22964)** finding shows that the scanner successfully identified services running on open ports. This may include application names or versions, which could help attackers determine potential vulnerabilities in the software being used.

The **General Information findings (Plugin ID: 54615 and 209654)** provide additional details about the target system, such as

configuration data, network responses, or service behavior. While these findings do not directly indicate security weaknesses, they reveal useful information that attackers could use to understand the system environment.

The **Settings Information (Plugin ID: 19506)** vulnerability highlights that certain configuration or system settings were detected during the scan. Exposure of configuration information may assist attackers in understanding how the system is structured and where potential weaknesses might exist.

To mitigate these issues, the Nessus report recommends several security measures such as disabling unnecessary services, limiting information disclosure, implementing firewalls and access control mechanisms, updating software regularly, and monitoring network activity using intrusion detection or prevention systems.

STAGE 3

TITLE:

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

1. Introduction to Legacy VPN Architectures

Legacy Virtual Private Network (VPN) architectures have traditionally been used by organizations to allow remote users to securely access internal corporate networks. VPNs create an encrypted tunnel between the user's device and the organization's network, allowing employees to work remotely. However, traditional VPN solutions often provide users with broad network access once connected. This can increase security risks because attackers who gain VPN access may move freely within the network. As organizations adopt cloud services and remote work models, legacy VPN architectures are becoming less effective and more vulnerable to modern cyber threats.

2. Overview of Zscaler Zero Trust Solution

Zscaler provides a cloud-native security platform designed to replace traditional VPN infrastructure. It follows the Zero Trust security model, where users are never trusted by default and must be

verified before accessing resources. Instead of connecting users to the entire network, Zscaler connects them only to the specific applications they are authorized to use. This approach improves security by preventing unauthorized access and protecting internal applications. Since Zscaler is delivered from the cloud, organizations do not need complex on-premise VPN hardware, making deployment easier and more scalable.

3. Limitations of Traditional VPN Security

Traditional VPN systems present several security and operational challenges. Once a user connects through VPN, they often gain access to large portions of the network, which increases the risk of unauthorized access and internal threats. VPN systems can also become overloaded when many users connect simultaneously, affecting performance and user experience. Additionally, managing VPN gateways and hardware infrastructure can be complex and costly. These limitations make legacy VPN solutions less suitable for modern cloud-based and remote working environments.

4. Zero Trust Network Access (ZTNA) with Zscaler

Zero Trust Network Access (ZTNA) is a security model that verifies every user and device before allowing access to applications. Zscaler implements ZTNA by ensuring that users can only access specific applications based on identity and security policies. Each access request is authenticated and authorized before a secure connection is established. This model prevents attackers from gaining full network access and significantly reduces the risk of

unauthorized activity. By adopting ZTNA, organizations can protect sensitive systems while maintaining secure connectivity for employees.

5. Reducing Attack Surface and Preventing Lateral Movement

One of the major advantages of replacing legacy VPN with Zscaler is the reduction of the attack surface. Traditional networks expose internal applications to connected users, making them potential targets for attackers. Zscaler hides internal applications from the public internet and only allows access through secure authentication. This prevents attackers from discovering or targeting these applications. Additionally, Zscaler limits user access to specific resources, preventing lateral movement within the network if a user account becomes compromised.

6. Benefits of Cloud-Native Security Architecture

Using a cloud-native security solution like Zscaler provides several operational and security benefits. Organizations can eliminate the need for maintaining VPN hardware and infrastructure. The cloud platform automatically scales to support a large number of users without affecting performance. Security policies can be centrally managed and applied consistently across all users and devices. This architecture also improves user experience by providing faster and more direct connections to applications regardless of location.

7. Challenges and Future Enhancements

Although transitioning from legacy VPN to a cloud-native Zero Trust solution offers many benefits, organizations may face challenges such as migration planning, integration with existing systems, and user training. Proper configuration and policy management are necessary to ensure secure access. In the future, advancements in artificial intelligence, automated threat detection, and adaptive security policies may further improve Zero Trust solutions. These technologies will help organizations build stronger, more resilient security frameworks to protect against evolving cyber threats.

SOC (Security Operations Center)

A Security Operations Center (SOC) is a centralized unit responsible for monitoring, detecting, analyzing, and responding to cybersecurity threats within an organization. The main purpose of a SOC is to protect an organization's network, systems, and sensitive data from cyber attacks. SOC teams use advanced security tools to continuously monitor system activities and identify suspicious behavior. The team usually consists of security analysts, incident responders, and SOC managers who work together to detect threats and respond quickly. A SOC operates 24/7 to ensure that any security incident is detected and handled immediately to minimize damage.

SOC Cycle

The SOC cycle represents the continuous process followed by a Security Operations Center to manage and respond to security threats. The cycle begins with monitoring network activities and collecting security logs from various devices such as servers, firewalls, and endpoints. When suspicious activity is detected, the SOC team analyzes the alerts to determine whether it is a real threat. If the threat is confirmed, the team responds by taking actions to contain and eliminate the attack. After resolving the incident, systems are recovered and restored to normal operation. Finally, the SOC team reviews the incident to improve security policies and prevent similar attacks in the future.

SIEM (Security Information and Event Management)

SIEM is a security solution that helps organizations collect, analyze, and manage security logs from multiple sources within a network. It combines Security Information Management (SIM) and Security Event Management (SEM) to provide both log storage and real-time security monitoring. SIEM tools gather log data from servers, firewalls, applications, and network devices and analyze this information to detect suspicious activities or potential threats. By correlating different events and generating alerts, SIEM helps security teams quickly identify cyber attacks and take appropriate actions. SIEM systems are widely used in SOC environments to enhance threat detection and improve overall security management.

SIEM Cycle

The SIEM cycle describes how security information flows through a

SIEM system to detect threats. The process begins with collecting logs from various devices such as firewalls, servers, routers, and applications. These logs are then normalized into a standard format so that they can be analyzed easily. After normalization, the SIEM system performs event correlation to identify patterns that may indicate a security threat. If suspicious activity is detected, the system generates alerts for security analysts. The analysts then investigate the alerts and take necessary actions to respond to the incident. This cycle helps organizations continuously monitor their network and maintain strong security.

MISP (Malware Information Sharing Platform)

MISP is an open-source threat intelligence platform designed to improve the sharing of cybersecurity information between organizations. It allows security teams to collect, store, and share Indicators of Compromise (IOCs) such as malicious IP addresses, malware file hashes, phishing URLs, and attack techniques. By sharing this information, organizations can detect and prevent cyber attacks more effectively. MISP supports collaboration among different security communities, enabling faster identification of emerging threats. It is commonly integrated with SOC and SIEM systems to enhance threat intelligence capabilities and strengthen overall cybersecurity defense.

College Network Information

A college network typically consists of various interconnected systems that support academic and administrative activities. The network includes student computers, faculty systems, campus WiFi,

laboratory computers, servers, and internet connectivity. It also supports services such as online learning platforms, digital libraries, email systems, and examination portals. Because many users access the network daily, the college network can become vulnerable to cyber threats such as malware, phishing attacks, and unauthorized access. Proper network security measures are required to protect sensitive information and ensure the smooth operation of academic systems.

Deploying SOC in College Network

Deploying a SOC in a college environment involves setting up a centralized system to monitor and protect the campus network from cyber threats. The first step is to assess the existing network infrastructure and identify all connected devices and systems. Security monitoring tools such as SIEM can then be deployed to collect logs from servers, firewalls, and network devices. A dedicated security team should be assigned to monitor alerts, analyze suspicious activities, and respond to security incidents. Threat intelligence platforms like MISP can also be integrated to provide information about new cyber threats. By implementing a SOC, colleges can improve network visibility, detect attacks early, and protect student and institutional data.

Threat Intelligence

Threat intelligence refers to the collection and analysis of information related to cyber threats and attackers. It helps organizations understand potential threats, how attacks occur, and how they can be prevented. Threat intelligence uses data such as

malicious IP addresses, malware signatures, vulnerabilities, and attacker behavior patterns. This information allows security teams to predict potential attacks and strengthen their defenses before an attack occurs. Threat intelligence is an important part of modern cybersecurity strategies and is widely used in SOC operations to enhance threat detection and response.

Incident Response

Incident response is the structured process used by organizations to manage and respond to cybersecurity incidents. A security incident may include malware infections, unauthorized access, data breaches, or denial-of-service attacks. The incident response process begins with preparation, where organizations establish security policies and response plans. When an incident occurs, it is detected and analyzed to understand its impact. The next step is containment, where actions are taken to stop the attack from spreading. After that, the threat is removed and systems are restored to normal operation. Finally, the incident is reviewed to improve security measures and prevent similar attacks in the future.

QRadar and Understanding the Tool

IBM QRadar is a powerful SIEM tool used by organizations to monitor security events and detect cyber threats in real time. It collects log data from multiple sources such as servers, network devices, and applications and analyzes this data to identify suspicious activities. QRadar uses advanced analytics and event correlation techniques to detect potential security threats and generate alerts for security analysts. It also provides dashboards and

visual reports that help SOC teams investigate incidents quickly. By using QRadar, organizations can improve their threat detection capabilities and respond to cyber attacks more efficiently.

Conclusion : Stage 1 – Overview of Tenable Nessus and Vulnerability Assessment

Stage 1 focused on understanding and using **Tenable Nessus** to perform vulnerability assessment on a target web application. Nessus is a widely used security scanning tool that helps identify weaknesses in networks, systems, and applications before attackers can exploit them. By scanning the target website **testphp.vulnweb.com (IP: 44.228.249.3)**, the tool analyzed the system configuration, exposed services, and security posture of the application.

During the scanning process, Nessus used its large plugin database to detect potential security issues and provide detailed information about each finding. The scan identified several **informational-level vulnerabilities** such as **Port Scanners, Service Detection, General Information, and Settings Information**. Although these findings are classified as informational and do not directly exploit the system, they reveal important details about open ports, running services, and system configuration that could potentially be used by attackers during the reconnaissance phase.

The results of the vulnerability scan also provided **recommended security solutions**, such as disabling unnecessary services, limiting information disclosure, applying firewall rules, updating software, and implementing monitoring systems like IDS/IPS. These recommendations help organizations strengthen their security configuration and reduce the chances of future cyberattacks.

Stage 3: Modernizing Legacy VPN with Zscaler Zero Trust Architecture

Stage 3 focuses on understanding how organizations can **replace traditional VPN architectures with a cloud-native Zero Trust solution using Zscaler**. In modern IT environments, many organizations still rely on legacy VPN systems to provide remote access to internal networks. However, these traditional systems often give users broad network access after authentication, which increases security risks and allows attackers to move laterally inside the network if a system is compromised.

To address these issues, modern cybersecurity strategies adopt the **Zero Trust security model**, where no user or device is trusted by default. Every access request must be verified before access to applications is granted. Zscaler provides a **cloud-native Zero Trust platform** that enables secure access to private applications without exposing the entire network.

In this architecture, users are not connected to the full corporate network like in traditional VPN systems. Instead, they are

connected **only to the specific applications they are authorized to access**. Zscaler verifies the user's identity, device posture, and security policies before allowing the connection. This significantly improves security and reduces the risk of unauthorized access.

One of the key advantages of replacing legacy VPN with Zscaler is the **reduction of the attack surface**. Traditional VPN systems expose internal resources to connected users, which can be discovered and exploited by attackers. Zscaler hides internal applications from the public internet and allows access only through secure authentication mechanisms.

Another important benefit is the **prevention of lateral movement**. In traditional networks, attackers who gain access to one system may move across the network to compromise additional systems. With Zscaler's **Zero Trust Network Access (ZTNA)** approach, users only receive limited access to specific applications, preventing attackers from moving across the network.

Cloud-native security architecture also provides operational advantages. Organizations no longer need to maintain complex VPN hardware infrastructure because Zscaler operates through a globally distributed cloud platform. Security policies can be centrally managed and applied consistently across all users and devices, improving both security and efficiency.

Future Enhancements

Stage 1: Future Enhancements – Tenable Nessus Vulnerability Assessment

In the future, vulnerability assessment using tools like **Tenable Nessus** can be further improved by integrating automated patch management and continuous monitoring systems. Organizations can implement **automated vulnerability remediation**, where detected vulnerabilities are automatically prioritized and fixed through security updates. Integration with **threat intelligence platforms** can also enhance vulnerability detection by identifying newly discovered threats in real time. Additionally, using **AI-based vulnerability analysis** can help security teams predict potential attack patterns and strengthen system defenses before attackers exploit weaknesses.

Stage 2: Future Enhancements – Nessus Vulnerability Analysis

Future improvements in vulnerability analysis will focus on **advanced risk prioritization and automated security response**. Instead of only identifying vulnerabilities, security systems may automatically classify threats based on their impact on business operations. Integration with **Security Information and Event Management (SIEM)** tools will allow vulnerability data to be correlated with real-time security events. This will help organizations detect potential attacks more quickly and respond efficiently. Machine learning technologies may also be used to analyze historical vulnerability data and recommend stronger security configurations.

Stage 3: Future Enhancements – Zscaler Zero Trust Architecture

Future developments in **Zscaler Zero Trust solutions** will focus on improving secure access, automation, and threat detection capabilities. Artificial intelligence and behavioral analytics may be used to continuously monitor user behavior and detect suspicious activities. Integration with **identity management systems and device security platforms** will allow organizations to enforce stronger access control policies. Additionally, future Zero Trust architectures may include automated policy adjustments that dynamically adapt security rules based on user risk levels, device security posture, and network conditions.

Topics Explored

During this project, several important cybersecurity concepts and technologies were explored to understand modern security practices and vulnerability management. The key topics covered include:

- **Tenable Nessus Vulnerability Scanner** and its role in identifying security weaknesses.
- **Vulnerability Assessment Process** and analysis of detected vulnerabilities.
- Understanding **plugin-based vulnerability detection** and severity classification.
- **Network reconnaissance techniques** such as port scanning and service detection.
- The importance of **information disclosure prevention and system hardening**.

- **Zero Trust Security Model** and its role in modern cybersecurity architecture.
- Replacement of **legacy VPN systems with cloud-native Zscaler Zero Trust solutions**.
- Methods for **reducing attack surface and preventing lateral movement** in networks.

Tools Explored

During this project, several cybersecurity tools and technologies were explored to perform vulnerability assessment, analyze security issues, and understand modern security architectures. These tools help security professionals identify weaknesses, monitor systems, and protect organizational infrastructure from cyber threats.

1. Tenable Nessus

Tenable Nessus is a widely used vulnerability scanning tool designed to detect security weaknesses in systems, networks, and web applications. It scans the target system and compares the results with its large vulnerability database to identify known vulnerabilities, misconfigurations, and outdated software. Nessus generates detailed reports that include vulnerability descriptions, severity levels, plugin IDs, and recommended remediation steps.

2. Vulnerable Test Web Application (testphp.vulnweb.com)

The website **testphp.vulnweb.com** was used as the target environment for vulnerability scanning. It is a deliberately vulnerable web application designed for security testing and learning purposes. This platform allows security professionals and

students to practice vulnerability assessment techniques without affecting real production systems.

3. Network and Web Application Scanning Techniques

During the vulnerability assessment process, different scanning techniques were explored such as port scanning, service detection, and system information gathering. These techniques help identify exposed services, open ports, and system configurations that could potentially be exploited by attackers.

4. Zscaler Zero Trust Security Platform

The Zscaler cloud security platform was explored to understand how modern organizations replace traditional VPN architectures with **Zero Trust Network Access (ZTNA)** solutions. Zscaler provides secure application access without exposing the internal network, helping reduce the attack surface and prevent lateral movement within the network.

5. Security Reporting and Vulnerability Analysis

Security reports generated by vulnerability scanners were analyzed to understand detected vulnerabilities, their severity levels, potential impact, and recommended solutions. This process helps organizations prioritize security fixes and strengthen their overall cybersecurity posture.

END
